Empoisonnement LLMNR/NBT-NS - Depuis Windows :

L'empoisonnement LLMNR/NBT-NS est également possible depuis un hote Windows, pour realiser cette attaque nous explorerons l'outil Inveigh
Il fonctionne de manière similaire à Responder il a une variante en Powershell mais aussi en C# (Plus à jours mais à compiler)
Voyons quelques version de la version Powershell pour cette attaque :
-LLMNR Y et -NBNS Y : "Oui" pour l'empoisonnement des requetes de diffusion de ces protocoles précis.
- ConsoleOutput Y : l'équivalent du mode verbeux de Responder il affiche les Hashs capturés et les requetes interceptés en temps réel dans notre console powershell
- FileOutput Y : Active l'enregistrement automatique de toutes nos captures (Hash) dans des fichier .txt (ecris sur le disque dur de la machine).

```
PS C:\Windows> Importe-Module .\Inveigh.ps1

PS C:\Windows> Invoke-Inveigh -LLMNR Y -NBNS Y -ConsoleOutput Y -FileOutput
```

Parlons de la version C# un peu plus mise à jours elle nécésite une compilation "Elle peux se lancer directement" par défault" pour realiser l'attaque. Dans la sortie les options [+] sont activés par défault contrairement a [-]

```
PS C:\Windows> .\Inveight.exe
```

La sortie nous montre aussi que l'on peux presser ESC pour entrer dans une console interactive (pareil pour en sortir) - Pour voir les options disponibles dans la console une fois dedans on peux taper HELP. Notons en quelque unes...
GET NTLMUSUNIQUE : visualiser les Hashs uniques capturés
GET NTLMUSUSERNAMES : voir en listes organisé les noms d'utilisateurs récoltés

- Il est important de noter que cette attaque puissante peux être bloqué de différent façon notemment fin en desactivant les protocoles LLMNR_NBNS, en surveillant ou bannissant le trafic de leurs ports - Ou en injectant des requetes pour des Hotes inexistant et en generant des "alertes rouges" si des réponses sont recus car elles indiquent logiquement la présence d'un attaquant.

Le Password Spraying (Introduction) :

La pulvérisation de mot de pass peux être un moyen très efficace d'obtenir un premier point d'ancrage interne, Mais elle peux causer des dommages considérables comme le verouillage de compte si elle est mal faite Il est donc essentiel d'introduire un délai entre les tentatives bien Choisir son mot de pass a tester mais surtout chercher à obtenir la politique de mot de pass de l'entreprise cible.

Enumeration de la Politique de MDP - Depuis Linux - Avec Credentials Valids :

Avec des identifiants valides la politique de mot de pass peux être obtenue à distance à l'aide de plusieurs outils comme nxc ou rpcclient

```
AgentpasRegex@parrot$ nxc smb ip -u username -p password --pass-pol
```

Enum Politique MDP - Depuis Linux - Null-Session SMB :

Les session nulles permettent à un attaquant non authentifié d'obtenir des informations sur le domaine - (lister les users, groupes, ordinateurs, attributs de comptes utilisateurs, politique de mot de pass).
On peux utiliser rpcclient pour se connecter a une session null et obtenir des informations sur le domaine...